

AC-14 — Permitted Actions without Identification or Authentication (L) (M) (H)

Document Type: Policy

Version: 1.0

Owner: Chief Information Security Officer (CISO)

Approver(s): CISO; Information System Owner (ISO); Information System Security Officer (ISSO)

Effective Date: TBD

Review Cycle: At least annually, or upon significant change

1. Purpose

This policy defines the organization-approved user actions that may be performed on the information system without prior identification or authentication, and documents the rationale consistent with mission/business functions, as required by NIST SP 800-53 Rev. 5, AC-14.

2. Scope

This policy applies to all publicly accessible organizational information systems, services, portals, and APIs that permit limited unauthenticated interactions. It covers workforce members, contractors, third-party users, and the general public where applicable.

3. Definitions

Identification: The process of uniquely recognizing a user of a system.

Authentication: Verifying the identity of a user, process, or device.

Unauthenticated Action: An allowed interaction without prior user identification or authentication.

4. Policy Statement

The organization permits specific, risk-evaluated actions to be performed without identification or authentication. Permitted actions are strictly read-only or narrowly scoped and are protected by compensating controls such as rate limiting, input validation, and logging. No access to nonpublic data or privileged functions is allowed without successful identification and authentication.

5. Permitted Unauthenticated Actions & Rationale (AC-14(a) & (b))

Permitted Action (Unauthenticated)	Examples (Non-Exhaustive)	Rationale (Mission/Business)
View public marketing & documentation pages	www.example.com/, /about, /pricing, /docs (public discov	Enable discovery of legal, privacy, legal, transparency, and
Access public service status & availability information	status.example.com, public uptime (historical)	Enable availability to users and stakeholders
Retrieve public API metadata (read-only)	GET /openapi.json, GET /api/v1/public/metadata	Enable system integration and developer support
Download public software/SDKs & whitepapers	/downloads/sdk.zip, /whitepapers/*.pdf (non-sensitive)	Facilitate developer onboarding and education without
Initiate account sign-up (no access until verified)	POST /signup (email capture and verification)	Facilitate legitimate trial or onboarding process

6. Prohibited Without Identification/Authentication

The following are not permitted without successful identification and authentication: access to or modification of any nonpublic data; user- or tenant-specific data views; administrative or configuration functions; state-changing API calls (except minimal sign-up initiation); bulk data export; or any action that could affect confidentiality, integrity, or availability of organizational data.

7. Compensating and Support Controls (Applied to Unauthenticated Interfaces)

a) Input validation and output encoding for all public endpoints; b) Rate limiting and bot mitigation (e.g., CAPTCHA) on forms and endpoints; c) Centralized logging of unauthenticated requests (timestamp, source IP, user agent); d) Monitoring & alerting for anomalies; e) Content security and privacy reviews for public artifacts; f) No storage of sensitive information in public responses.

8. Roles and Responsibilities

System Owner (ISO): Ensures permitted unauthenticated actions remain aligned to mission and approves changes.

ISSO: Documents actions in the SSP and maintains rationale; ensures periodic review.

Engineering: Implements controls (rate limiting, validation, logging) and restricts access to nonpublic data.

Security (CISO/SecOps): Reviews public endpoints, monitors logs, and validates compensating controls are active.

9. Procedures (How Implemented)

1) Maintain an inventory of public endpoints and pages. 2) For any new unauthenticated action, perform a risk assessment and obtain ISO/ISSO approval. 3) Update the SSP with the action and supporting rationale. 4) Validate and document compensating controls (rate limits, logging, monitoring). 5) Review the inventory at least annually or upon significant change; remove or reclassify actions as needed.

10. Evidence Expected by Auditors

- Current policy document and version history;
- Inventory of permitted unauthenticated actions with rationale;
- Screenshots or exports of rate limiting/bot mitigation settings;
- Log samples showing unauthenticated request capture;
- SSP excerpts mapping AC-14(a) and (b);
- Annual review records and approvals.

11. References & Mappings

- NIST SP 800-53 Rev. 5, AC-14 — Permitted Actions without Identification or Authentication.
- FedRAMP Moderate Baseline.
- Organizational Access Control Policy (AC-1).

AC-14 — Control Summary Information

Responsible Role:	Chief Information Security Officer (CISO); Information System Owner (ISO); Information
Parameter AC-14(a):	Permitted unauthenticated actions limited to: (1) Public marketing & documentation pag

Implementation Status (check one): ☒ Implemented ☐ Partially implemented ☐ Planned ☐ Alternative implementation ☐ Not applicable

Control Origination (check all that apply):

☒ Service Provider Corporate ☒ Service Provider System Specific ☐ Service Provider Hybrid ☐ Configured by Customer ☐ Provided by Customer ☐ Shared ☐ Inherited

AC-14 — What is the solution and how is it implemented?

Part a — Identify user actions allowed without identification/authentication:

The organization allows unauthenticated access to public marketing and documentation, public service status, public API metadata, and public downloads. Users may initiate account sign-up without prior authentication; no tenant data is accessible until verification completes.

Part b — Document & provide rationale in the SSP:

The SSP enumerates each unauthenticated action with its business justification, risk analysis, and compensating controls (rate limiting, input validation, centralized logging, and monitoring). The SSP is updated upon changes and reviewed at least annually.

Approvals

CISO: _____ Date: _____

ISO: _____ Date: _____

ISSO: _____ Date: _____